

Security Assessment Report

Generated: 2026-05-04 14:24

Report ID: 004fb057

Executive Security Report

Executive Summary

Total vulnerabilities: 3

Highbest risk issues: 0; the scan found only lowseverity code quality/security concerns, with limited immediate business impact but some potential for abuse or reliability issues.

Overall risk level: Low

Technical Details

Finding 1 Use of subprocess for security tooling execution

Severity: Low

AI Explanation: The application uses subprocess to launch a scanner command. This is not automatically unsafe, but it increases risk if inputs are not tightly controlled and if the executable path is not fixed.

Fix Suggestion: Use an absolute path to the executable, validate and constrain request.path, and prefer safer process invocation patterns or wrapper APIs.

Finding 2 Partial executable path in subprocess call

Severity: Low

AI Explanation: The code runs bandit without an absolute path, which can allow PATHbased command confusion if the environment is compromised or misconfigured.

Fix Suggestion: Call the binary via a fully qualified path and ensure the runtime environment has a restricted, trusted PATH.

Finding 3 Subprocess invocation with untrusted input risk

Severity: Low

AI Explanation: The scanner path is passed into a subprocess call. Even without shell=True, untrusted or malformed paths can cause unintended behavior or scanning of unexpected locations.

Fix Suggestion: Strictly validate input paths, restrict scans to approved directories, and reject special characters or path traversal attempts.

Tool outcomes (Bandit, Sonar, Safety, ZAP):

Bandit: Succeeded

Sonar: Succeeded

Safety: Failed/not run; no dependency manifest or explicit dependency scan target was provided

ZAP: Failed/not run; no HTTP/HTTPS target URL was provided

Tool Failures

Safety was not run because the provided input appears to be source code rather than a project folder with dependency metadata.

ZAP was not run because the provided input is not an HTTP/HTTPS URL.